

SecCheck

API & MCP 연계 가이드

REST API 와 Model Context Protocol 로 SecCheck 에 연결하기

버전	v1.0.146
작성일	2026-09-17
문서	API & MCP 연계 가이드

SecCheck API & MCP 연계 가이드 (API & MCP Guide)

SecCheck 는 시스템 연계 및 CI/CD 자동화를 위한 REST API와 AI 에이전트(Claude Desktop, Cursor 등) 연동을 위한 Model Context Protocol (MCP) 인터페이스를 제공합니다.

1. 인증 체계 (Authentication)

모든 API 및 MCP 호출은 개인 키 관리(/profile/keys)에서 발급받은 Bearer API Key 또는 세션 쿠키를 사용합니다:

```
Authorization: Bearer sck_a1b2c3d4_XXXXXXXXXXXXXXXXXXXXXXXXXXXX
```

1-1. OpenAPI 명세

전체 API 명세는 로그인 상태에서 GET /api/openapi.json 으로 받습니다. 명세는 서버의 라우트 등록 테이블에서 생성되므로 문서화되지 않은 엔드포인트가 존재할 수 없습니다. 각 operation에는 다음이 포함됩니다.

- summary · tags — 한글 설명과 기능 분류
- operationId — 메서드와 경로에서 파생된 안정적인 식별자 (클라이언트 자동 생성용)
- parameters — 경로 파라미터 선언
- requestBody — 본문을 받는 operation의 JSON 속성과 타입. 서버가 알 수 없는 속성을 거부하므로 스키마도 additionalProperties: false 입니다. 즉 명세대로 보내면 그대로 통과합니다
- x-object-scoped — true 이면 역할이 아니라 대상 심의에 대한 접근 권한으로 판단합니다. 요청자·공동 작성자·지정된 검토자·승인자가 해당하며, 조회는 SECURITY_REVIEWER 와 AUDITOR 도 모든 심의에 접근합니다. SYSTEM_ADMIN 은 포함되지 않습니다 — 서비스 운영 권한이 남의 심의 열람 권한은 아닙니다. 권한이 없으면 404이므로, 역할만 보고 호출 가능 여부를 판단하면 안 됩니다
- x-required-roles — 호출에 필요한 RBAC 역할. 빈 배열이면 로그인한 모든 사용자가 호출 가능
- security: [] — 인증 없이 호출 가능한 엔드포인트 (/api/v1/auth/login , /api/v1/public/config 등)

아래 표는 자주 쓰는 엔드포인트만 추린 것이며, 전체 목록은 명세를 참조하십시오.

2. REST API 주요 엔드포인트 (/api/v1)

심의 요청 및 관리 (Review Requests)

메서드	경로	설명	권한
GET	/review-requests	심의 목록 조회 (필터: q , status)	전체 (권한 범위의 심의만 반환)
POST	/review-requests	신규 심의 생성 및 Rule Engine 자동 배정	REQUESTER
GET	/review-requests/{id}	심의 상세 정보 및 진행 통계 조회	담당자, 검토자, 승인자
GET	/review-requests/{id}/items	심의에 배정된 체크리스트 항목 및 답변 목록	담당자, 검토자, 승인자
PUT	/review-requests/{id}/responses/{itemID}	체크리스트 항목 작성 및 자동 저장	해당 심의 참여자
GET	/review-requests/{id}/submission-check	제출을 막는 미완료 항목 목록 (ready , issues). 제출 전에 미리 확인	담당자, 검토자, 승인자
GET	/review-requests/{id}/completion-check	검토 완료를 막는 항목 목록 (ready , issues). 검토자용	담당자, 검토자, 승인자
GET	/review-requests/{id}/assignees	항목 담당자로 지정할 수 있는 사용자 목록	담당자, 검토자, 승인자
GET	/review-requests/{id}/items/{itemID}/verdict-history	같은 서비스의 이전 심의에서 이 항목이 받은 판정	담당자, 검토자, 승인자
POST	/review-requests/{id}/transfer-requester	심의 요청자를 다른 사람에게 인계	요청자 본인 또는 시스템 관리자
POST	/review-requests/{id}/submit	심의 제출 (서버 검증 실행)	해당 심의 참여자
POST	/review-requests/{id}/begin-review	보안 검토 시작 (REVIEWING 전환)	SECURITY_REVIEWER
PUT	/review-requests/{id}/review-results/{itemID}	항목별 검토 결과 및 의견 저장	SECURITY_REVIEWER
POST	/review-requests/{id}/approve	심의 최종 승인	APPROVER
POST	/review-requests/{id}/reject	심의 반려	APPROVER
POST	/review-requests/{id}/reopen	반려 심의 보완 재개(보완 필요 로 되돌림)	SECURITY_REVIEWER
POST	/review-requests/{id}/withdraw-approval	결재 요청 회수(검토 중 으로 되돌림)	SECURITY_REVIEWER

증거 파일 (Evidences)

메서드	경로	설명	권한
POST	/review-requests/{id}/items/{itemID}/evidences	증거 파일 암호화 업로드 (multipart/form-data)	해당 심의 참여자
GET	/evidences/{id}/download	증거 파일 복호화 다운로드	권한자
POST	/evidences/{id}/versions	증거 파일 신규 버전 교체 등록	해당 심의 참여자

통합 Security Controls & 템플릿

메서드	경로	설명	권한
POST	/review-requests/{id}/change-requests/bulk	선택 항목 일괄 보완 요청	SECURITY_REVIEWER
POST	/admin/settings/upload/test	ClamAV(clamd) 연결 테스트	SYSTEM_ADMIN
POST	/admin/settings/mail/test	저장된 메일 설정으로 본인(또는 recipient)에게 테스트 메일 1통을 그 자리에서 발송. 결과는 발송 기록에도 남음	SYSTEM_ADMIN
GET	/admin/mail/deliveries	메일 발송 기록. 시도마다 event, recipient, subject, status (SENT · FAILED · SKIPPED), attempt, error. 본문은 없음. status, limit, offset	SYSTEM_ADMIN
GET	/api/v1/integrations	연계 정보와 MCP 도구 목록. mcp_oauth (enabled, 켜져 있으면 resource · metadata_url · authorization_server · scopes)	로그인 사용자
GET	/admin/users/{id}/open-work	계정이 아직 닫고 있는 진행 중 심의·미이행 후속조치 수	SYSTEM_ADMIN
GET	/admin/api-keys	설치 전체의 API 키와 소유자·마지막 사용 시각	SYSTEM_ADMIN
POST	/admin/api-keys/{id}/revoke	다른 사용자의 API 키 폐기	SYSTEM_ADMIN
GET	/admin/analytics/violations	방문 추적이 켜진 뒤 콘텐츠 보안 정책이 차단한 출처 목록(origin, directive, page, count, allowed)	SYSTEM_ADMIN
DELETE	/admin/analytics/violations	차단된 출처 목록 비우기	SYSTEM_ADMIN
POST	/admin/analytics/allow	차단된 출처 하나(origin)를 방문 추적 설정의 allowed_hosts에 추가	SYSTEM_ADMIN
POST	/api/v1/analytics/csp-report	브라우저의 콘텐츠 보안 정책 위반 신고(application/csp-report). 방문 추적이 켜진 동안만 기록하며 항상 204	없음
GET	/security-controls	통합 Security Control 목록 및 영향 통계	전체
GET	/security-controls/{id}/impact	연결된 체크리스트와 영향 심의 범위, 그리고 이 Control의 판정 이력({items, outcomes})	
GET	/templates	체크리스트 템플릿 목록 및 게시 버전 조회	전체
GET	/templates/{id}/rule-check	게시된 체크리스트에서 심의에 쓸 수 없는 항목(규칙 오류로 배정되지 않거나, 선택지가 없어 답할 수 없는 항목)	TEMPLATE_ADMIN, SECURITY_REVIEWER

2-1. 오류 응답과 코드

실패 응답은 모두 같은 형태입니다. 연계 스크립트는 HTTP 상태보다 error.code 로 분기하십시오. 문구(message)는 사용자에게 보여 주기 위한 것이라 릴리즈마다 다듬어지지만, 코드는 계약입니다.

```
{ "error": { "code": "REVIEW_INCOMPLETE", "message": "미검토 항목 2건이 남아 검토를 완료할 수 없습니다.", "details": { "unrev
```

details 는 코드마다 다르며 없을 수도 있습니다(null).

인증·권한

코드	뜻
AUTHENTICATION_REQUIRED	세션이나 API 키가 없습니다
MCP_OAUTH_DISABLED	<code>/.well-known/oauth-protected-resource</code> — 이 설치 MCP SSO 토큰을 받지 않습니다 (404). 개인 키를 쓰거나 관리자가 켜야 합니다
SESSION_REQUIRED	이 작업은 브라우저 세션에서만 가능합니다
INVALID_CREDENTIALS	아이디 또는 비밀번호가 틀렸습니다
LOGIN_RATE_LIMITED	로그인 시도가 제한 횟수를 넘었습니다
ACCOUNT_LOCKED	로그인 실패가 누적되어 잠긴 계정입니다
TOTP_REQUIRED / TOTP_INVALID / TOTP_FAILED	2단계 인증 코드가 필요·불일치·처리 실패
TOTP_ENROLLMENT_REQUIRED	정책상 2단계 인증 등록이 먼저 필요합니다
PASSWORD_CHANGE_REQUIRED	관리자가 발급한 임시 비밀번호입니다. 본인이 변경해야 다른 요청이 허용됩니다(API 키에는 적용되지 않음)
LAST_PUBLISHED_VERSION	사용 중인 템플릿의 마지막 게시 버전은 중지할 수 없습니다. 새 버전을 게시하거나 템플릿을 사용 안 함으로 바꾼 뒤 중지하세요
API_KEY_LIFETIME	요청한 만료일이 설치에 설정된 API 키 최대 유효기간을 넘습니다
INVALID_RULE	적용 규칙에 오류가 있는 항목이 있어 버전을 게시할 수 없습니다. <code>details</code> 에 항목과 사유가 담깁니다
CSRF_INVALID	CSRF 토큰이 없거나 일치하지 않습니다
RATE_LIMITED	요청 빈도 제한을 넘었습니다
API_SCOPE_FORBIDDEN	API 키의 scope로는 허용되지 않는 작업입니다
FORBIDDEN	권한이 없거나 대상 심의에 참여하지 않습니다
SELF_REVIEW_FORBIDDEN	본인이 신청한 심의는 본인이 검토·승인할 수 없습니다
SELF_APPROVAL_FORBIDDEN	본인이 검토·판정한 심의는 본인이 최종 승인할 수 없습니다
SESSION_SWEEP_FAILED	자격 증명은 바뀌었으나 이 계정의 로그인 세션을 종료하지 못했습니다(다시 시도하십시오)
EXTERNAL_ACCOUNT	외부(OIDC) 계정에는 적용할 수 없는 작업입니다
SELF_LOCKOUT / LAST_ADMIN_PROTECTION	자기 계정 비활성화·관리자 역할 제거는 막습니다
CURRENT_SESSION	지금 사용 중인 세션은 종료 대상에서 제외됩니다

요청 내용

코드	뜻
INVALID_JSON	본문을 JSON으로 읽을 수 없습니다
VALIDATION_FAILED	필드 값이 규칙에 맞지 않습니다(details 에 필드별 사유)
NA_REASON_REQUIRED	N/A 선택 시 사유가 필요합니다
DUE_DATE_REQUIRED / FOLLOW_UP_DUE_REQUIRED	보완 요청·후속조치에는 기한이 필요합니다
REASON_REQUIRED	제출한 심의를 취소하려면 사유가 필요합니다(검토자·승인자에게 전달됩니다)
WEAK_PASSWORD	비밀번호가 정책에 맞지 않습니다(12자 이상, 혼한 비밀번호·아이디·서비스 이름·같은 문자 반복·연속 문자 불가). details 에 사유가 담깁니다
NOT_FOUND	대상이 없거나 접근 범위 밖입니다
FORMAT_NOT_SUPPORTED	지원하지 않는 내보내기 형식입니다
UPLOAD_REJECTED	확장자·크기·MIME 검증에 걸렸습니다
DUPLICATE_ITEM_CODE	같은 버전에 같은 항목코드가 이미 있습니다
NOT_A_PARTICIPANT	심의에 참여하지 않는 사용자에게는 배정할 수 없습니다

상태 충돌 (409·422)

코드	뜻
STATE_CONFLICT	현재 상태에서 허용되지 않는 전이입니다
SUBMISSION_INCOMPLETE	제출 전 검증에 걸렸습니다(details 에 항목별 사유)
REVIEW_INCOMPLETE	미검토 항목·미검증 보완 요청·판정 후 변경 항목이 남았습니다
RESPONSE_CONFLICT / REVIEW_RESULT_CONFLICT	다른 사용자가 먼저 저장했습니다(최신 값이 details 에)
ALREADY_ASSIGNED / ITEM_ALREADY_USED	이미 배정·사용 중이라 다시 적용할 수 없습니다
IMMUTABLE_VERSION	게시된 템플릿 버전은 수정할 수 없습니다
EMPTY_VERSION	항목이 없는 버전은 게시할 수 없습니다
TEMPLATE_IN_USE / CONTROL_IN_USE	사용 중이라 삭제할 수 없습니다
SCAN_NOT_CLEARED	악성코드 검사가 끝나지 않은 증적입니다
EVIDENCE_PURGED	보존기간이 지나 파기된 증적입니다
VERIFY_IN_PROGRESS	같은 검증이 이미 실행 중입니다

서버·인프라 (5xx)

코드	뜻
QUERY_FAILED / SEARCH_FAILED	데이터베이스 조회에 실패했습니다
CREATE_FAILED / UPDATE_FAILED / DELETE_FAILED / COPY_FAILED	저장에 실패했습니다
SUBMIT_FAILED / SNAPSHOT_FAILED	제출·스냅샷 처리에 실패했습니다
UPLOAD_FAILED / STORAGE_FAILED	증적 저장에 실패했습니다
KEY_UNAVAILABLE / ENCRYPTION_FAILED / ROTATE_FAILED	암호화 키를 쓸 수 없습니다
EXPORT_FAILED / FONT_MISSING	내보내기에 실패했습니다(PDF는 한글 폰트 필요)
IMPORT_FAILED / DIFF_FAILED	Excel 가져오기·버전 비교에 실패했습니다
VERIFY_FAILED	감사 체인 검증을 수행하지 못했습니다
SMTP_FAILED / OIDC_DISCOVERY_FAILED / OIDC_INVALID / CLAMAV_FAILED	외부 연동 설정 확인에 실패했습니다
NOT_READY	데이터베이스에 연결할 수 없어 지표·준비 상태를 제공할 수 없습니다

3. Model Context Protocol (MCP) 엔드포인트

- **엔드포인트:** POST /mcp
- **프로토콜 버전:** MCP 2026-07-28 Stateless Streamable HTTP (구형 2025-11-25 호환)
- **인증:** Authorization: Bearer <API_KEY> — 관리자가 MCP SSO 를 컨 설치에서는 같은 헤더로 Keycloak 액세스 토큰도 받습니다 (아래 "키 없이 SSO 로 연결")

🔑 키 없이 SSO 로 연결 (OAuth 2.1)

관리자가 서비스 설정 > MCP SSO 를 켜 두었으면 개인 키를 만들 필요가 없습니다. MCP 클라이언트(Claude, Cursor 등)에 MCP 주소 하나(<https://<공개 주소>/mcp>)만 넣으면 됩니다 — 클라이언트가 401 응답의 WWW-Authenticate: Bearer resource_metadata="..." 를 따라 GET /.well-known/oauth-protected-resource/mcp 를 읽고, 거기 적힌 Keycloak 으로 로그인 화면을 띄워 토큰을 받아 옵니다. 이미 Keycloak 에 로그인돼 있으면 화면은 거의 보이지 않습니다. 주소는 API · MCP 연계 화면의 키 없이 SSO 로 연결 에 있습니다.

- 토큰은 /mcp 에서만 받습니다. REST 에는 개인 키나 세션이 여전히 필요합니다.
- **웹으로 한 번 로그인한 계정**이어야 합니다. 토큰이 계정을 만들지 않으며, 비활성 계정은 열리지 않습니다.
- 권한은 그 계정이 가진 역할·심의 접근 범위 그대로이고, 범위(read / read:write)는 관리자의 SSO 토큰 범위 설정이 정합니다.
- Keycloak 에서 로그아웃해도 이미 발급된 토큰은 만료까지 유효합니다(수명은 관리자가 짧게 둥니다).
- 메타데이터 문서는 인증 없이, 제품 응답 봉투 없이 맨 JSON 으로 나옵니다. MCP SSO 가 꺼진 설치에서는 404(MCP_OAUTH_DISABLED) 입니다.

```
curl -s https://seccheck.example/.well-known/oauth-protected-resource/mcp
# {"resource":"https://seccheck.example/mcp","authorization_servers":["https://keycloak.example/realms/company"],"bearer_meth
```

제공 도구 목록 (Tools)

1. `seccheck.dashboard` : 대시보드 통계 및 긴급 처리 건수 조회
2. `seccheck.list_reviews` : 상태 및 키워드 기반 심의 목록 검색
3. `seccheck.get_review` : 특정 심의의 상세 정보, 진행률, 체크리스트 항목 조회
4. `seccheck.search_controls` : Security Control 및 체크리스트 가이드 검색
5. `seccheck.validate_submission` : 제출 전 누락 항목 및 결함 사전 검증
6. `seccheck.my_queue` : 지금 본인이 처리해야 하는 심의와 기한이 임박한 보완 요청 조회
7. `seccheck.review_report` : 기간별 처리 현황·소요 기간·부서별 집계·반복 미흡 항목 조회 (`SYSTEM_ADMIN` , `SECURITY_REVIEWER` , `AUDITOR` , `APPROVER`)

도구는 모두 호출자의 권한 범위 안에서만 답합니다. 위키 전용이 아닌 도구를 API 키로 호출하려면 키에 쓰기 범위가 있어야 하며, 전체 목록과 입력 스키마는 `tools/list` 로 확인합니다.

MCP 호출 예시 (JSON-RPC 2.0)

요청: 심의 제출 전 결함 사전 검증

```
{
  "jsonrpc": "2.0",
  "id": "req-201",
  "method": "tools/call",
  "params": {
    "name": "seccheck.validate_submission",
    "arguments": {
      "review_id": "9b1deb4d-3b7d-4bad-9bdd-2b0d7b3dcb6d"
    }
  }
}
```

응답

```
{
  "jsonrpc": "2.0",
  "id": "req-201",
  "result": {
    "content": [
      {
        "type": "text",
        "text": "검증 결과: 제출 가능한 상태입니다. (작성 완료: 45/45, 필수 증거 첨부: 12건)"
      }
    ]
  }
}
```